02 Soc2

SOC 2 Type II Readiness — MEDPLUM

Company: Anticloud FZ LLE **Model:** PAX L5 Narrow L2 General 27B
Trust Service Criteria: Security, Availability, Confidentiality, Processing Integrity, Privacy

CC1 — Control Environment

Criteria Evidence Status
--- --- ---
CC1.1 COSO Principles Documented in OFFICIAL_BENCHMARKS PASS
CC1.2 Board oversight Anticloud FZ LLE governance docs PASS
CC1.3 Management philosophy Single-owner accountability (Lois-Kleinner Alpasan) PASS

CC2 — Communication & Information

Criteria Evidence Status
--- --- ---
CC2.1 COSO objectives Anticloud offline-first architecture documented PASS
CC2.2 Internal communication Local observability stack (traces/metrics/logs) PASS
CC2.3 External communication Anticommons 0.1.0 public license PASS

CC6 — Logical & Physical Access (Security)

Criteria Evidence Status
--- --- ---
CC6.1 Logical access security Zero-trust mTLS mesh, short-lived certs PASS
CC6.2 Authentication mTLS client certificates, no shared secrets PASS
CC6.3 Role-based access CRDT identity + AIOSS audit per role PASS
CC6.6 Logical access restrictions Air-gapped deployment option PASS
CC6.7 Unauthorized removal AES-256-GCM encryption, key rotation PASS
CC6.8 Malware prevention Deterministic builds + source hash verification PASS

CC7 — System Operations

Criteria Evidence Status
--- --- ---
CC7.1 Configuration management Deterministic builds, SBOM in binary PASS
CC7.2 Infrastructure monitoring Local observability: OpenTelemetry traces PASS
CC7.3 Environmental threats Offline-first, no cloud dependency PASS
CC7.4 Incident detection AIOSS anomaly detection via chain breaks PASS

CC8 — Change Management

Criteria Evidence Status
--- --- ---
CC8.1 Change management Provenance chain records every computation PASS

A1 — Availability

99.99% theoretical uptime — no cloud dependency means no cloud outage risk.
Single binary deploys in < 30 seconds on any x86/ARM node.

C1 — Confidentiality

AES-256-GCM encryption at rest. Zero plaintext storage of sensitive data.
Sovereign Memory encrypts all persisted entries with scrypt-derived keys.

PI1 — Processing Integrity

AIOSS ledger provides cryptographic proof of processing integrity.
Every computation recorded in Provenance chain with input/output hashes.